MW REALTY · TESTER HANDBOOK · PROJECT DOCUMENT P3

Application Access, Roles & Permissions

Where each part of MW Realty lives, which account to use for which test, and what every role may see and do.

Scope: Public website, Admin / CMS (`/admin`), partner CRM (`/crm`) and the mobile-app APIs, in every test environment. Covers environments and entry points, test accounts by role, role descriptions, the CRM permission matrix with KYC / plan / 2FA locks, the Admin permission names and the menus they unlock, and how testers get sign-up, sign-in and 2FA codes. Sources: the tester handbook (00 overview, 21 My Profile, 22 Security, 23 Plans, 24-26) and the code (`app/Services/Crm/CrmNavigation.php` , `routes/crm.php` , `routes/web.php` , `config/cms/permissions.php` , the Admin sidebar layout and `app/Http/Middleware`).

1. Environments

Environment	URL	Purpose	Notes
QA / UAT	https://mw.realty.mightywarnersdemo.com	Functional, regression and acceptance testing by the QA team.	Stripe in test mode, test mailbox or mail log, DLD / ADREC online check usually off. Ask the project lead for the exact settings (section 6).
Production	To be provided by the project lead	The live marketplace used by real agencies, agents and buyers.	Do not test here. No sign-ups, enquiries, payments, ads or imports. If a page looks like the live site, stop and report it.

1.1 Entry points (same paths on every environment)

Area	Path	Who signs in	Notes
Public website	`/`	Nobody (visitor) or a Customer	Single-page app: `/properties` , `/commercial` , `/premium-properties` , `/marketing-properties` , `/property-details/{slug}` , `/compare` , `/agents` , `/agencies` , `/blogs` , `/market-insights` , calculators, `/contact` , `/profile` .
Sign up / Log in	`/signup` , `/login` , `/verify-email` , `/forgot-password`	Customer ("User" tab), Agent or Agency ("Agent / Agency" tab)	Old links `/agent-login` , `/agency-login` , `/portal/login` , `/agent-signup` , `/agency-signup` redirect here. Google sign-in (`/customer/auth/google`) is for customers only.
Admin / CMS	`/admin` (sign-in at `/admin/login` , reset at `/admin/password/reset`)	MW Realty staff (Admin users with a role)	Menu depends on the user's permissions (section 5).
Partner CRM	`/crm` (sign in through `/login` > Agent / Agency tab)	Agency and Agent accounts; the Super Admin through the CRM button in the Admin top bar	Opening `/crm` while signed out sends you to `/login` . 2FA set-up page: `/crm/security/two-factor` .

Area	Path	Who signs in	Notes
Legacy partner screens	`/portal/...`	Same as CRM	A few screens not yet moved to `/crm` (for example My Agency at `/portal/agency`).

1.2 API base paths and API documentation

API	Base path	Authentication	Documentation (open in a browser)
Website / Customer app API	`/api/...` (for example `/api/properties`, `/api/compare`, `/api/chatbot/message`, `/api/leads/capture`)	Public endpoints need none. Customer endpoints under `/api/customer/...` need a Bearer token from `POST /api/auth/login` or `POST /api/auth/verify-otp`.	Full website API: `/docs/frontend/`. Customer app subset (Entry, Home, Search, Saved, Activity, Account): `/docs/app-customer/`
CRM API (web CRM and agent app)	`/api/crm/...` (for example `/api/crm/leads`, `/api/crm/properties`, `/api/crm/navigation`)	The web CRM uses the browser session. The agent app uses a Bearer token from `POST /api/crm/auth/login` (plus the email-code and 2FA steps).	Full CRM API: `/docs/crm/`. Agent app subset (Entry, Home, Leads, Add listing, Listings, More): `/docs/app-agent/`
Webhooks (not for manual testing)	`/api/stripe/webhook`, `/api/webhooks/facebook`	Signed by Stripe / Meta	Not documented for testers.

> The `/docs/...` pages are Scribe-generated documentation read from `public/docs/_scribe/<name>/openapi.yaml`. If a page is empty on an environment, ask a developer to run the docs generation for that environment.

2. Test accounts by role

Never create partner accounts with real company documents, and never use real buyers' or agents' details. Ask the project lead for the accounts below for your environment.

Role	Sign-in page	How to get an account	Credentials
Visitor	None	No account needed. Use a private browser window to start as a new anonymous visitor.	Not applicable
Customer ("User")	`/login` > User tab, or Continue with Google	Self sign-up at `/signup` > User tab with a test mailbox you control.	Shared separately
Agency A (approved, paid plan with all gated features, team agents, ads, Premium)	`/login` > Agent / Agency tab	Provided by the project lead (KYC approval and plan assignment are done in Admin).	Shared separately
Agency B (approved, Free plan)	`/login` > Agent / Agency tab	Provided by the project lead, or self sign-up then approval by Super Admin in Admin > Clients.	Shared separately

Role	Sign-in page	How to get an account	Credentials
Agency C (KYC pending)	`/login` > Agent / Agency tab	Self sign-up at `/signup` > Agency tab; do not submit, or submit and leave unapproved.	Shared separately
Independent agent (approved, own plan)	`/login` > Agent / Agency tab	Provided by the project lead, or self sign-up at `/signup` > Agent tab then approval.	Shared separately
Agency agent A1 (approved member of Agency A)	`/login` > Agent / Agency tab	Created by Agency A in CRM > Agents and approved in Admin > Clients > Agency Agents. The set-password email goes to the test mailbox.	Shared separately
Super Admin	`/admin/login`, then the CRM button in the top bar	Provided by the project lead only.	Shared separately
Admin staff (limited role)	`/admin/login`	Created by the Super Admin in Admin > User Management > Admins with a test role.	Shared separately
Mobile app tester tokens	`POST /api/auth/login` (customer) or `POST /api/crm/auth/login` (agent / agency)	Same accounts as above; tokens are issued per device.	Shared separately

> Write down the role, KYC state and plan of the account in every bug report. Many differences between two testers' screens come from these three values.

3. Roles

3.1 Visitor

Anyone on the website without signing in. Can search, open listings, compare, use calculators and Market Insights, send enquiries, viewing requests and contact forms, download brochures and floor plans (after giving contact details) and ask the AI chat one free question. Activity is tracked anonymously by a browser cookie until the visitor identifies themselves; then they become a website lead and the earlier activity is attached to them.

3.2 Customer

A buyer or tenant account (shown as "User"). Signs in at `/login` > User tab or with Google. Has `/profile` with Overview, Wishlist, Saved Searches, My Enquiries and Account Settings. A customer cannot open the CRM or the Admin. Signing up or signing in creates a website lead in the Super Admin's pool.

3.3 Agency (company account)

A real-estate company. Owns the plan, credits, listings and leads, and a team of agents. Sees its own data and its agents' data. Can add or invite agents, accept join requests, set round-robin lead assignment, and make 2FA compulsory for its agents. Most CRM modules are locked until its KYC is approved by the Super Admin.

3.4 Agent: independent vs agency member

	Independent agent	Agency agent (approved member)
Plan and credits	Own plan, own credits wallet, own Plans and Credits pages.	Uses the agency's plan; no Credits page; plan page shows the agency plan card only ("Plan · via agency"). Plan-locked sections say "Ask your agency to upgrade."
Listings	Own listings, count against own plan.	New listings belong to the agency and count against the agency plan; sees own listings plus agency listings assigned to them.
Leads	Own leads.	Own personal leads plus agency leads assigned to them.
Advertisements	Yes, if own plan includes ads.	Hidden. Calling the page directly answers "Advertising is managed by your agency."
My Agency	Can accept invitations or request to join an agency.	Sees the membership; can leave.
2FA	Can disable 2FA unless the site requires it.	Cannot disable 2FA when the agency requires it.

An agent has one account for life; joining, leaving and re-joining an agency only add membership records. An agent who only typed a brokerage name in the profile stays independent.

3.5 Super Admin

The Admin user with the `superadmin` role. Has every Admin permission, is the only role that can change admins, roles and permissions, and is the only user with the CRM button. In the CRM the Super Admin has no partner account of their own: they see every account's data, use Super-Admin-only modules (Website Leads, Listing Permits, Listing Review, Marketing Properties, Property Options, advertisement review and placements, Property Finder import review) and their account menu shows only Back to Admin. Listings the Super Admin creates are MW Realty's own ("house listings").

3.6 Admin staff roles

Other MW Realty staff sign in at `/admin` with a role made of permissions (section 5). Two roles are defined in `config/cms/permissions.php`:

- `superadmin` (label Super Admin): all permissions.
- `client` (label Client): a small content-editor set: `testimonials.view`, `testimonials.edit`, `site-information.view`, `site-information.edit`, `languages.view`, `metadata.view`, `faqs.view`, `faqs.edit`, `enquiries.view`, `enquiries.edit`, `careers.view`.

Further roles are created by the Super Admin in Admin > User Management > Roles. Staff roles never get the CRM button. A missing Admin menu item usually means a missing `.view` permission; a refused save (403) usually means a missing `.create`, `.edit` or `.delete` permission.

> The Admin "Client" staff role is unrelated to the "Clients" menu (partner accounts). Do not confuse the two in bug reports.

4. CRM permission matrix

4.1 Locks that apply before the matrix

Lock	When	What the tester sees
2FA set-up	The site requires 2FA (`TWO_FACTOR_REQUIRED`, default on) or the agency requires it, and the account has not set it up.	Every menu item except Security has a padlock "Set up two-factor authentication first" and no badge counts; the user is held at `/crm/security/two-factor`.
KYC	Account status is not approved.	Padlock "Unlocks after KYC approval"; the item cannot be opened; opening its URL gives "Your account is pending Super Admin approval." Banner at the top of the CRM.
Plan feature	The plan (or the agency's plan) does not include the feature.	Padlock "Upgrade your plan to unlock this" (Reports: "Upgrade your plan to unlock reports"; Ads: "Upgrade your plan to advertise on the website"). The page opens and shows an "Unlock ..." card instead of data.
Data scope	Always.	An agency sees its own and its team's data; an agent sees own and assigned data; the Super Admin sees everything. Another account's record ID typed in a URL must be refused.

4.2 Module access by role

Legend: Yes = full use within the role's data scope; Own = only the account's own records; No = hidden or refused.

CRM module (path)	Super Admin	Agency	Independent agent	Agency agent	Lock
Dashboard (`/crm`)	Yes, all accounts	Yes	Yes	Yes	None
Leads, Follow-ups (`/crm/leads`)	Any lead; owner filter, transfer	Own and team's leads; assign agent	Own	Own personal leads + agency leads assigned to them	KYC
Lead Insights	All accounts	Own leads	Own leads	Own + assigned (agency plan)	KYC, plan `lead_insights`
Website Leads	Yes (pool, transfer)	No (refused)	No	No	Super Admin only
Master > Stage, Tag, Source	Shared items for all accounts	Own items + shared	Own items + shared	Own items + shared	KYC
Master > Property Options	Yes	No ("Only Super Admin can manage property options.")	No	No	Super Admin only

CRM module (path)	Super Admin	Agency	Independent agent	Agency agent	Lock
Integrations (Facebook, Property Finder, Excel / CSV tile)	All Pages, assigns owner; Property Finder import review	Own	Own	Own Facebook Pages (personal); can sync the agency's Property Finder connection but not change it	KYC, plan `facebook` or `property_finder` (hub opens if either is included)
Properties, Commercial	All listings, no plan limit	Own + team; plan slots or credits	Own; plan slots or credits	Own + assigned; agency plan	KYC
Property insights (on a listing)	Yes	Yes	Yes	Yes (agency plan)	Plan `property_insights`
Import from Excel / CSV (`/crm/properties/import`)	No (page opens, upload refused)	Into own account	Into own account	Into the agency's account	KYC; free listing slots on the plan
Write with AI (listing form)	Yes	Yes	Yes	Yes	AI provider configured on the server
Premium	Any listing, no limits	Own listings: plan quota or credits	Own listings: plan quota or credits	Own listings only, agency plan quota; no credits	KYC
Advertisements	MW Realty ads, client ad review, placements and pricing	If plan includes ads	If plan includes ads	No (hidden)	KYC, plan ads (a maximum ad length set on the plan)
Sold Listings	All accounts	Own	Own	Own + assigned	Shown only when the account has sold / rented listings
Marketing Properties	Yes	No	No	No	Super Admin only
My Agency (`/portal/agency`)	No	No	Yes (invitations, requests)	Yes (membership, leave)	Agents only
Agents (team, round robin)	All agents, read-only (approvals in Admin)	Own team; add / invite within plan agent limit	No	No	KYC
Nearby Places	Shared places	Own places + shared	Own + shared	Own + shared	KYC

CRM module (path)	Super Admin	Agency	Independent agent	Agency agent	Lock
Listing Settings (watermark)	Default watermark; sees all accounts'	Own	Own	Read-only (agency's)	KYC, plan `listing_settings`
Listing Permits	Yes	No (403)	No (403)	No (403)	Super Admin only
Listing Review	Yes	No (403)	No (403)	No (403)	Super Admin only
Reports	Always, all tabs, plan sales	Leads, Properties, Sales, Agents tabs	Leads, Properties, Sales	No Agents tab	KYC, plan reports access
Contact Us (support tickets)	No (Admin > Support Tickets)	Own tickets	Own tickets	Own tickets (the agency does not see them)	None
Help Desk	Yes	Yes	Yes	Yes	None
My Profile	No ("My Profile belongs to agent and company accounts.")	Yes	Yes	Yes	Never locked
Security (2FA)	No (Admin has its own sign-in)	Yes, plus "2-Factor Authentication (My Company)" switch	Yes	Yes; cannot disable if agency requires it	Never locked
Plans	No (403)	Choose, pay, cancel, invoices	Choose, pay, cancel, invoices	Agency plan card only; nothing to buy	KYC for choosing or buying (payment history stays open)
Credits	Open by URL; history of all accounts	Own wallet	Own wallet	No ("Credits are managed by your agency")	KYC; credits switched on in Admin (or credits still held)

4.3 Plan feature locks

Plan setting	Unlocks	Lock text in the menu
Gated feature `lead_insights`	Leads > Lead Insights	Upgrade your plan to unlock this
Gated feature `property_insights`	Property insights on a CRM listing	(card on the listing)
Gated feature `listing_settings`	Listings > Listing Settings (watermark)	Upgrade your plan to unlock this

Plan setting	Unlocks	Lock text in the menu
Gated feature `facebook`	Integrations > Facebook Lead Ads	Upgrade your plan to unlock this (hub locked only if neither integration is included)
Gated feature `property_finder`	Integrations > Property Finder	Same as above
Reports access (on / off)	Insights > Reports	Upgrade your plan to unlock reports
Ads per month and longest booking	Listings > Advertisements	Upgrade your plan to advertise on the website
Agent limit	Adding agents in Agents; agency agents inheriting the plan	Offer to upgrade when the limit is reached
Listing allowance, Premium quota	Adding listings, Premium bookings	Offer of credits or upgrade when used up

Default plans (Admin can change every value in Admin > Plans, so confirm the current values in your environment):

Plan	Price (AED) month / year	Listings	Premium	Ads (per month, longest)	Agents	Reports	Gated features
Free	0	3 at once	None	None	0	No	None
Basic	49 / 490	10 per month	1 per month, max 5 days	None	0	Yes	Listing settings, Property Finder
Pro	149 / 1,490	25 per month	3 per month, max 15 days	4, 24 hours	3	Yes	Listing settings, Lead insights, Property Finder
Business	299 / 2,990	50 per month	5 per month, max 20 days	6, 48 hours	10	Yes	All five
Enterprise	499 / 4,990	100 per month	10 per month, no day limit	10, 72 hours	Unlimited	Yes	All five

5. Admin permissions

Permissions use the `cms` guard and the pattern `<module>.<action>`. The standard actions are `view`, `create`, `edit` and `delete`. `.view` shows the menu item and opens the list; saving, toggling status and reordering need `.edit`; adding needs `.create`; deleting needs `.delete`. Only the `superadmin` role may save changes in User Management, whatever permissions another role holds.

Admin menu	Permission names	Notes
Dashboard	(any signed-in admin)	
Clients > Agents, Agencies, Agency Agents, Plan Upgrade Requests	`portal-accounts.view`, `portal-accounts.edit`, `portal-accounts.delete`	KYC review, enable / disable, reset password or 2FA, assign plan, memberships. Super Admin always sees it.

Admin menu	Permission names	Notes
Plans, Payments	`plans.view`, `plans.create`, `plans.edit`, `plans.delete`	Payments uses `plans.view`.
Credits	`credits.view`, `credits.edit`	Switch on / off, price, validity, grant credits.
Credit History	`credit-history.view`	Ledger of all accounts, export.
Coupons	`coupons.view`, `coupons.create`, `coupons.edit`, `coupons.delete`	
Support Tickets	`support-tickets.view`, `support-tickets.edit`	Replies to CRM Contact Us tickets.
Help Desk	`help-desk.view`, `help-desk.create`, `help-desk.edit`, `help-desk.delete`	Quick guides shown on CRM screens.
General Settings > Languages, Currencies, Site Information	`languages.*`, `currencies.view`, `currencies.create`, `currencies.edit`, `currencies.delete`, `site-information.view`, `site-information.edit`	Translations of website text are under Languages.
SEO Management > Metadata, Sitemap, Robots.txt, LLMs.txt, URL Redirects, 404 Logs	`metadata.*`, `sitemap.view`, `sitemap.edit`, `robots-txt.view`, `robots-txt.edit`, `llms-txt.view`, `llms-txt.edit`, `url-redirects.view`, `url-redirects.edit`, `url-miss-logs.view`, `url-miss-logs.edit`	
Home > Banners, Popular Places, Section Headings; Luxury Projects	`banners.*`, `popular-places.*`, `section-headings.view`, `section-headings.edit`, `luxury-projects.view`, `luxury-projects.edit`	
About > About Us, Market Trends, Why Choose Us, Our Builders, Connect Us, Post Property Steps	`about-us.*`, `market-trends.*`, `why-choose-us.*`, `our-builders.*`, `connect-us.*`, `post-property-steps.*`	
Contact Us (page content)	`contact-us.view`, `contact-us.edit`	
Calculators	`calculators.*`	Copy, FAQs and enquiry form text of the four calculators.
Filters > Filters, Communities, Find Properties	`filters.*`, `communities.*`, `find-properties.*`	
Brands, Testimonials	`brands.*`, `testimonials.*`	
FAQs, Locations	`faqs.*`, `locations.*`	Modules switched off in `config/cms/common.php`; menus hidden.
Enquiries > Enquiries, Newsletter, Unassigned leads	`enquiries.view`, `enquiries.show`, `enquiries.delete`, `enquiries.export`, `newsletter.view`, `newsletter.delete`	Unassigned leads appears only when there are some.

Admin menu	Permission names	Notes
Blogs > Blogs, Categories	`blogs.view`, `blogs.create`, `blogs.edit`, `blogs.delete`, `blog-categories.*`	
Market Insights (+ Topics, Regions)	`market-insights.view`, `market-insights.create`, `market-insights.edit`, `market-insights.delete`	Topics and Regions share these.
Landing Pages	`landing-pages.*`	Includes landing page enquiries.
Careers (Vacancies, Departments, Candidates)	`careers.view`, `careers.create`, `careers.edit`, `careers.delete`, `careers.show`, `careers.export`	
Advertisements (redirect to CRM)	`ads.view`	Ads are managed in the CRM by the Super Admin.
User Management > Admins, Roles, Permissions	`users.*`, `roles.*`, `permissions.*`	Changes are allowed for the `superadmin` role only.
CRM button (top bar)	`superadmin` role	Not a permission; cannot be granted to other roles.

`*` = the four standard actions (`view`, `create`, `edit`, `delete`) where the module uses them.

5.1 Suggested Admin permission tests

- Create a role with only `blogs.view`: Blogs menu shows, other menus are hidden, saving a blog returns 403.
- Add `blogs.edit`: editing works, adding still refused until `blogs.create`.
- A non-superadmin role with `roles.edit` still cannot save a role or assign permissions (403).
- A staff user never sees the CRM button and `/crm` refuses them.

6. Codes: email verification, OTP and 2FA

Code	Where it is asked	Format and life	How to get it in QA
Sign-up email code (Customer, Agent, Agency) and email-change code	`/verify-email` after sign-up; My Profile > Change email	4 digits, valid 10 minutes; Resend sends a new one. Wrong or old: "Invalid or expired code."	If `OTP_ENABLED=true`, the code is emailed (see below). If `OTP_ENABLED=false`, no email is sent and the fixed test code set in `OTP_STATIC_CODE` is accepted. Ask the project lead which applies and for the code.
New-device email code (2FA on)	CRM sign-in from a browser not seen before: "Verify it's you"	6 digits, valid 10 minutes; the whole sign-in attempt expires after 15 minutes; 5 wrong codes end the attempt.	Emailed. With `OTP_ENABLED=false` on a non-production environment the fixed test code is also accepted at this step.
Authenticator app code	CRM sign-in when 2FA is on; 2FA set-up	6 digits, changes every 30 seconds; set-up QR valid 30 minutes.	Use any authenticator app (Google Authenticator, Microsoft Authenticator, Authy) on a test phone. Keep the device time correct.

Code	Where it is asked	Format and life	How to get it in QA
Recovery code	Instead of the app code at sign-in	8 codes shown once, format `XXXXX-XXXXX`, each usable once.	Save them from the set-up screen; "Generate new codes" replaces them.
Locked-out partner			Super Admin: Admin > Clients > account > Reset 2FA.

How emails reach testers in QA:

- `MAIL_MAILER=log` (the default in `.env.example`): no email is sent; every email, including codes, is written into the application log `storage/logs/laravel.log`. Testers without server access must ask a developer to read the code from the log.
- `MAIL_MAILER=smtp` pointing at a shared test inbox (for example a Mailpit or Mailtrap sandbox): emails arrive in that inbox. This is the recommended QA set-up; the project lead shares the inbox access separately.
- Most emails are queued and sent by the background worker, so allow 1-2 minutes. Sign-up and login codes are sent immediately.

2FA behaviour to verify:

- `TWO_FACTOR_REQUIRED` (default true): every agency and agent must set up an authenticator app before using the CRM; Skip is not offered. When false, Skip for now is offered unless the agency has made 2FA compulsory for its agents.
- With 2FA on, a new browser asks first for the email code, then for the app code. A browser verified once is trusted; a device not used for 180 days is no longer trusted.
- Disabling 2FA needs the password; an agency agent cannot disable it while the agency requires it.

> Rate limits apply per network (IP) address: 5 login attempts per minute per email, 8 code checks per minute and 30 per day, 10 sign-ups per hour. "Too many requests" after hitting them is expected, not a bug. Testers sharing one office IP address can hit them together.